

Workgroup: fapi
Published: 19 March 2025
Authors: D. Tonge D. Fett J. Heenan
Moneyhub Financial Technology Authlete Authlete

FAPI 2.0 Message Signing (Draft)

Foreword

The OpenID Foundation (OIDF) promotes, protects and nurtures the OpenID community and technologies. As a non-profit international standardizing body, it is comprised by over 160 participating entities (workgroup participant). The work of preparing implementer drafts and final international standards is carried out through OIDF workgroups in accordance with the OpenID Process. Participants interested in a subject for which a workgroup has been established have the right to be represented in that workgroup. International organizations, governmental and non-governmental, in liaison with OIDF, also take part in the work. OIDF collaborates closely with other standardizing bodies in the related fields.

Final drafts adopted by the Workgroup through consensus are circulated publicly for the public review for 60 days and for the OIDF members for voting. Publication as an OIDF Standard requires approval by at least 50% of the members casting a vote. There is a possibility that some of the elements of this document may be the subject to patent rights. OIDF shall not be held responsible for identifying any or all such patent rights.

Introduction

OIDF FAPI 2.0 is an API security profile based on the OAuth 2.0 Authorization Framework [RFC6749]. This Message Signing Profile is part of the FAPI 2.0 family of specifications with a focus on providing interoperable support for non-repudiation across OAuth 2.0 based requests and responses.

Warning

This document is not an OIDF International Standard. It is distributed for review and comment. It is subject to change without notice and may not be referred to as an International Standard.

Recipients of this draft are invited to submit, with their comments, notification of any relevant patent rights of which they are aware and to provide supporting documentation.

Notational conventions

The keywords "shall", "shall not", "should", "should not", "may", and "can" in this document are to be interpreted as described in ISO Directive Part 2 [ISODIR2]. These keywords are not used as dictionary terms such that any occurrence of them shall be interpreted as keywords and are not to be interpreted with their natural language meanings.

Table of Contents

1. [Scope](#)
2. [Normative references](#)
3. [Terms and definitions](#)
4. [Symbols and Abbreviated terms](#)

5. Message signing profile

5.1. Profile

5.2. Non-repudiation

5.3. Signing authorization requests

5.3.1. Requirements for authorization servers

5.3.2. Requirements for clients

5.3.3. Client metadata

5.4. Signing authorization responses

5.4.1. Requirements for authorization servers

5.4.2. Requirements for clients

5.5. Signing introspection responses

5.5.1. Requirements for authorization servers

5.5.2. Requirements for clients

5.6. Signing ID tokens

5.6.1. Requirements for authorization servers

5.6.2. Requirements for clients

6. Security considerations

6.1. Authorization response encryption

6.2. Confusion between resource servers and clients in introspection request

6.3. Non-repudiation limited to individual messages

6.4. Non-repudiation not provided for front channel authorization requests

6.5. Difficulty in linking a signed message to a real world identity

6.6. The value of JARM for non-repudiation

7. Privacy considerations

8. IANA considerations

8.1. OAuth dynamic client registration metadata registration

8.1.1. Registry contents

9. Acknowledgements

10. Normative References

11. Informative References

Appendix A. Notices

Authors' Addresses

1. Scope

This document specifies the methods for clients, authorization servers and resource servers to sign and verify messages.

2. Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

See Clause 8 for normative references.

3. Terms and definitions

For the purpose of this document, the terms defined in [\[RFC6749\]](#), [\[RFC6750\]](#), [\[RFC7636\]](#), [\[OIDC\]](#) and [\[ISO29100\]](#) apply.

4. Symbols and Abbreviated terms

API – Application Programming Interface

HTTP – Hyper Text Transfer Protocol

JAR – JWT-Secured Authorization Request

JARM – JWT Secured Authorization Response Mode

JWT – JSON Web Token

JSON – JavaScript Object Notation

OIDF – OpenID Foundation

PAR – Pushed Authorization Requests

PKCE – Proof Key for Code Exchange

REST – Representational State Transfer

TLS – Transport Layer Security

URI – Uniform Resource Identifier

URL – Uniform Resource Locator

5. Message signing profile

OIDF FAPI 2.0 is an API security profile based on the OAuth 2.0 Authorization Framework [\[RFC6749\]](#). This Message Signing Profile aims to reach the security goals laid out in the Attacker Model [\[attackermodel\]](#) plus the non-repudiation goals listed below.

All provisions of the [\[FAPI2_Security_Profile_ID2\]](#) apply to the Message Signing Profile as well, with the extensions described in the following.

5.1. Profile

In addition to the technologies used in the [\[FAPI2_Security_Profile_ID2\]](#), the following standards are used in this profile:

- OAuth 2.0 JWT Secured Authorization Request (JAR) [\[RFC9101\]](#) for signing authorization requests
- JWT Secured Authorization Response Mode for OAuth 2.0 [\[JARM\]](#) for signing authorization responses
- OAuth 2.0 Token Introspection [\[RFC7662\]](#) with [\[RFC9701\]](#) for signing introspection responses

We understand that some ecosystems may only desire to implement 1, 2 or 3 of the above, it is therefore anticipated that a piece of software will be able to conform to each of the methods separately, i.e. there will be separate conformance testing options for each of the following:

- Signed authorization requests
- Signed authorization responses
- Signed introspection responses

5.2. Non-repudiation

Beyond what is captured by the security goals and the attacker model in [\[attackermodel\]](#), parties could try to deny having sent a particular message, for example, a payment request. For this purpose, non-repudiation is needed.

In the context of this specification, non-repudiation refers to the assurance that the owner of a signature key pair that was capable of generating an existing signature corresponding to certain data cannot convincingly deny having signed the data ([\[NIST.SP.800-133\]](#)).

This is usually achieved by providing application-level signatures that can be stored together with the payload and meaningful metadata of a request or response.

The following messages are affected by this specification:

- NR1: pushed authorization requests
- NR2: authorization requests (front-channel)
- NR3: authorization responses (front-channel)
- NR4: introspection responses
- NR5: ID tokens

5.3. Signing authorization requests

To support non-repudiation for NR1, pushed authorization requests can be signed. Because FAPI2 uses [\[RFC9126\]](#), NR2 is achieved by default when the pushed authorization request is signed.

5.3.1. Requirements for authorization servers

Authorization servers implementing FAPI2 authorization request signing

1. shall support, require use of, and verify signed request objects according to JAR [\[RFC9101\]](#) at the PAR endpoint [\[RFC9126\]](#);
2. shall require the aud claim in the request object to be, or to be an array containing, the authorization server's issuer identifier URL;
3. shall require the request object to contain an nbf claim that is no longer than 60 minutes in the past; and
4. shall require the request object to contain an exp claim that has a lifetime of no longer than 60 minutes after the nbf claim;
5. shall accept request objects with typ header parameter with a value oauth-authz-req+jwt.

5.3.2. Requirements for clients

Clients implementing FAPI2 authorization request signing

1. shall send all authorization parameters to the PAR endpoint [RFC9126] in a JAR [RFC9101] signed requested object;
2. shall send the aud claim in the request object as the authorization server's issuer identifier URL;
3. shall send a nbf claim in the request object;
4. shall send an exp claim in the request object that has a lifetime of no longer than 60 minutes;
5. should send a typ header parameter with a value oauth-authz-req+jwt.

5.3.3. Client metadata

The Dynamic Client Registration Protocol [RFC7591] defines an API for dynamically registering OAuth 2.0 client metadata with authorization servers. The metadata defined by [RFC7591], and registered extensions to it, also imply a general data model for clients that is useful for authorization server implementations even when the dynamic client registration protocol isn't in play. Such implementations will typically have some sort of user interface available for managing client configuration.

The following client metadata parameter is introduced by this specification:

- response_modes:
 - OPTIONAL. A JSON array of strings containing the list of response modes that the client may use. If omitted, the default is that the client may use any of the response modes supported by the authorization server.

5.4. Signing authorization responses

To support non-repudiation for NR3, authorization responses can be signed.

5.4.1. Requirements for authorization servers

Authorization servers implementing FAPI2 authorization response signing

1. shall support, require use of, and issue signed authorization responses via JWT Secured Authorization Response Mode for OAuth 2.0 [JARM].

NOTE: When using [JARM] an authorization server should only include the iss authorization response parameter defined by [RFC9207] inside the JWT. This is because [RFC9207] defines iss to be an authorization response parameter, and [JARM] Section 4.1 requires all authorization response parameters to be inside the JWT.

5.4.2. Requirements for clients

Clients implementing FAPI2 authorization response signing

1. shall set the response_mode to jwt in the authorization request as defined in [JARM]; and
2. shall verify signed authorization responses according to [JARM].

5.5. Signing introspection responses

To support non-repudiation for NR4, introspection responses can be signed.

5.5.1. Requirements for authorization servers

Authorization servers implementing FAPI2 introspection response signing

1. shall sign introspection responses that are issued in JWT format according to [RFC9701]

5.5.2. Requirements for clients

Clients implementing FAPI2 introspection response signing

1. shall request signed token introspection responses according to [\[RFC9701\]](#); and
2. shall verify the signed token introspection responses.

5.6. Signing ID tokens

To support non-repudiation for NR5, signed ID tokens are used.

5.6.1. Requirements for authorization servers

No additional requirements.

Note: Authorization servers implementing FAPI2 are already required to sign ID tokens as specified in section 5.4.1 in the [\[FAPI2_Security_Profile_ID2\]](#).

5.6.2. Requirements for clients

Clients requesting and receiving ID tokens

1. shall verify the signature of the signed ID token received.

6. Security considerations

6.1. Authorization response encryption

In FAPI2, there is no confidential information in the authorization response, hence encryption of the authorization response is not required for the purposes of security or confidentiality. In addition, to achieve greater interoperability, it is not recommended to use encryption in this case.

Usage of PKCE in FAPI 2 provides protection for code leakage described in Section 5.4 of [\[JARM\]](#).

6.2. Confusion between resource servers and clients in introspection request

In [\[RFC9701\]](#), the resource server accessing the introspection endpoint is seen in the role of a client towards the authorization server that is providing the introspection endpoint. A malicious client (that is not a resource server) could attempt to call the introspection endpoint directly, and thus gather information about an access token to which it is not supposed to have access. This may, for example, leak secrets including, if the access token was leaked or stolen, personal information about an end-user.

The authorization server therefore must ensure that the resource server is not confused with a regular client that is not supposed to call the introspection endpoint, and that the resource server has the necessary authorization to access the information associated with the access token.

6.3. Non-repudiation limited to individual messages

It is important to note that while this specification provides mechanisms for non-repudiation for individual messages, it does not provide non-repudiation guarantees for a sequence of messages.

6.4. Non-repudiation not provided for front channel authorization requests

While only a small amount of information is present in a [\[FAPI2_Security_Profile_ID2\]](#) front channel authorization request, it is important to note that non-repudiation is not provided for this message.

6.5. Difficulty in linking a signed message to a real world identity

This specification provides the technical means to sign messages, however proving that a specific signed response is linked to a specific real world end-user, or that a real world end-user initiated a specific request is outside of the scope of this document.

6.6. The value of JARM for non-repudiation

The values signed in a JARM response may be of limited value for non-repudiation as the values are artifacts of the OAuth flow (e.g. code and state) rather than real world values (e.g. account number and amount). However JARM is still useful in providing message integrity to the authorization response.

7. Privacy considerations

In addition to the privacy considerations detailed in [FAPI2_Security_Profile_ID2] implementers should consider the privacy implications of storing messages for the purpose of non-repudiation.

Such messages may well contain personally identifiable information and implementers should evaluate whether such messages need to be stored. If they are stored then adequate access controls must be put in place to protect that data. Such controls should follow data minimisation principles and ensure that there are tamper-proof audit logs.

8. IANA considerations

8.1. OAuth dynamic client registration metadata registration

This specification requests registration of the following client metadata definitions in the IANA "OAuth Dynamic Client Registration Metadata" registry established by [RFC7591]:

8.1.1. Registry contents

- Client Metadata Name: response_modes
- Client Metadata Description: Array of the response modes that the client may use
- Change Controller: IESG
- Specification Document(s): [Section 5.3.3](#) of this specification

9. Acknowledgements

This specification was developed by the OpenID FAPI Working Group.

We would like to thank Takahiko Kawasaki, Filip Skokan, Nat Sakimura, Dima Postnikov, Brian Campbell, Ralph Bragg, Justin Richer and Lukasz Jaromin for their valuable feedback and contributions that helped to evolve this specification.

10. Normative References

- [FAPI2_Security_Profile_ID2] Fett, D., "FAPI 2.0 Security Profile", 18 September 2024, <https://openid.net/specs/fapi-2_0-security-profile-ID2.html>.
- [ISO29100] ISO/IEC, "ISO/IEC 29100 Information technology – Security techniques – Privacy framework", <<https://standards.iso.org/ittf/PubliclyAvailableStandards/index.html#:~:text=IEC%2029100%3A2011-,EN,-%2D%20FR>>.
- [JARM] Lodderstedt, T. and B. Campbell, "JWT Secured Authorization Response Mode for OAuth 2.0 (JARM)", 9 November 2022, <<https://openid.net/specs/oauth-v2-jarm-final.html>>.
- [NIST.SP.800-133] Barker, E. and A. Roginsky, "NIST Special Publication 800-133", 23 July 2019, <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-133.pdf>>.
- [OIDC] Sakimura, N., Bradley, J., Jones, M., de Medeiros, B., and C. Mortimore, "OpenID Connect Core 1.0 incorporating errata set 1", 8 November 2014, <http://openid.net/specs/openid-connect-core-1_0.html>.

- [RFC6749] Hardt, D., Ed., "The OAuth 2.0 Authorization Framework", RFC 6749, DOI 10.17487/RFC6749, October 2012, <<https://www.rfc-editor.org/info/rfc6749>>.
- [RFC6750] Jones, M. and D. Hardt, "The OAuth 2.0 Authorization Framework: Bearer Token Usage", RFC 6750, DOI 10.17487/RFC6750, October 2012, <<https://www.rfc-editor.org/info/rfc6750>>.
- [RFC7636] Sakimura, N., Ed., Bradley, J., and N. Agarwal, "Proof Key for Code Exchange by OAuth Public Clients", RFC 7636, DOI 10.17487/RFC7636, September 2015, <<https://www.rfc-editor.org/info/rfc7636>>.
- [RFC7662] Richer, J., Ed., "OAuth 2.0 Token Introspection", RFC 7662, DOI 10.17487/RFC7662, October 2015, <<https://www.rfc-editor.org/info/rfc7662>>.
- [RFC9101] Sakimura, N., Bradley, J., and M. Jones, "The OAuth 2.0 Authorization Framework: JWT-Secured Authorization Request (JAR)", RFC 9101, DOI 10.17487/RFC9101, August 2021, <<https://www.rfc-editor.org/info/rfc9101>>.
- [RFC9126] Lodderstedt, T., Campbell, B., Sakimura, N., Tonge, D., and F. Skokan, "OAuth 2.0 Pushed Authorization Requests", RFC 9126, DOI 10.17487/RFC9126, September 2021, <<https://www.rfc-editor.org/info/rfc9126>>.
- [RFC9207] Meyer zu Selhausen, K. and D. Fett, "OAuth 2.0 Authorization Server Issuer Identification", RFC 9207, DOI 10.17487/RFC9207, March 2022, <<https://www.rfc-editor.org/info/rfc9207>>.
- [RFC9701] Lodderstedt, T., Ed. and V. Dzhuvinov, "JSON Web Token (JWT) Response for OAuth Token Introspection", RFC 9701, DOI 10.17487/RFC9701, January 2025, <<https://www.rfc-editor.org/info/rfc9701>>.
- [attackermodel] Fett, D., "FAPI 2.0 Attacker Model", 7 December 2022, <https://openid.net/specs/fapi-2_0-attacker-model-ID2.html>.

11. Informative References

- [ISODIR2] ISO/IEC, "ISO/IEC Directives, Part 2 - Principles and rules for the structure and drafting of ISO and IEC documents", <<https://www.iso.org/sites/directives/current/part2/index.xhtml>>.
- [RFC7591] Richer, J., Ed., Jones, M., Bradley, J., Machulak, M., and P. Hunt, "OAuth 2.0 Dynamic Client Registration Protocol", RFC 7591, DOI 10.17487/RFC7591, July 2015, <<https://www.rfc-editor.org/info/rfc7591>>.

Appendix A. Notices

Copyright (c) 2025 The OpenID Foundation.

The OpenID Foundation (OIDF) grants to any Contributor, developer, implementer, or other interested party a non-exclusive, royalty free, worldwide copyright license to reproduce, prepare derivative works from, distribute, perform and display, this Implementers Draft or Final Specification solely for the purposes of (i) developing specifications, and (ii) implementing Implementers Drafts and Final Specifications based on such documents, provided that attribution be made to the OIDF as the source of the material, but that such attribution does not indicate an endorsement by the OIDF.

The technology described in this specification was made available from contributions from various sources, including members of the OpenID Foundation and others. Although the OpenID Foundation has taken steps to help ensure that the technology is available for distribution, it takes no position regarding the validity or scope of any intellectual property or other rights that might be claimed to pertain to the implementation or use of the technology described in this specification or the extent to which any license under such rights might or might not be available; neither does it represent that it has made any independent effort to identify any such rights. The OpenID Foundation and the contributors to this specification make no (and hereby expressly disclaim any) warranties (express, implied, or otherwise), including implied warranties of merchantability, non-infringement, fitness for a particular purpose, or title, related to this specification, and the entire risk as to implementing this specification is assumed by the implementer.

The OpenID Intellectual Property Rights policy requires contributors to offer a patent promise not to assert certain patent claims against other contributors and against implementers. The OpenID Foundation invites any interested party to bring to its attention any copyrights, patents, patent applications, or other proprietary rights that may cover technology that may be required to practice this specification.

Authors' Addresses

Dave Tonge

Moneyhub Financial Technology

Email: dave@tonge.org**Daniel Fett**

Authlete

Email: mail@danielfett.de**Joseph Heenan**

Authlete

Email: joseph@authlete.com